1. Introduction

Within this document, an *event* is any observable occurrence that involves computing assets, including physical and virtual platforms, networks, services, and cloud environments. Examples of events are user login attempts, the installation of software updates, and an application responding to a transaction request. Many events focus on security or have security implications. *Adverse events* are any events associated with a negative consequence regardless of cause, including natural disasters, power failures, or cybersecurity attacks. This guide addresses only *adverse cybersecurity events*. Additional analysis is often needed to determine whether adverse cybersecurity events indicate that a cybersecurity incident has occurred.

A *cybersecurity incident* (or simply *incident*) is

> …an occurrence that actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system; or constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies. [FISMA2014]

Examples of incidents include an attacker:

- Employing a botnet to send high volumes of connection requests to an internet-facing service, making it unavailable to legitimate service users
- Obtaining administrative credentials at a software-as-a-service provider, which puts sensitive tenant data entrusted to that provider at risk
- Intruding upon an organization's business network to steal credentials and use them to instruct industrial control systems to shut down or destroy critical physical components, causing a major service disruption
- Deploying ransomware to prevent the use of computer systems and cause multiple data breaches by copying files from those systems
- Using phishing emails to compromise user accounts and using those accounts to commit financial fraud
- Identifying a new vulnerability in network management appliances and exploiting the vulnerability to gain unauthorized access to network communications
- Compromising a vendor's software, which is subsequently distributed to customers in its compromised state

Because of the damage that cybersecurity incidents can inflict on organizations and their customers, business partners, and others, it is vital to respond quickly and effectively when an incident occurs. Effective implementation of incident response processes enables systematic responses to and recovery from incidents by analyzing information and taking appropriate action. This reduces cybersecurity and enterprise risks by minimizing data loss or theft, the disruption of services, and the overall impact of incidents. Lessons learned from incident response activities and root cause analysis help improve cybersecurity risk management and

governance efforts and ensure that the organization is better prepared to identify its current technology assets and cybersecurity risks, protect its assets, and detect, respond to, and recover from future incidents.

1.1. Purpose and Scope

This publication seeks to help organizations incorporate cybersecurity incident response recommendations and considerations throughout their cybersecurity risk management activities. It also provides a common language that all organizations can use to communicate internally and externally regarding their incident response plans and activities.

The scope of this publication differs significantly from previous versions. Because the details of how to perform incident response activities change so often and vary so much across technologies, environments, and organizations, it is no longer feasible to capture and maintain that information in a single static publication. Instead, this version focuses on improving cybersecurity risk management for all of the NIST Cybersecurity Framework (CSF) 2.0 Functions [CSF2.0] to better support an organization's incident response capabilities.

Readers are encouraged to utilize other NIST resources in conjunction with this document, including the CSF 2.0 publication and supplemental resources, the Incident Response project page, and mappings to additional sources of information on implementing incident response considerations available through the NIST Cybersecurity and Privacy Reference Tool (CPRT). An example of a CPRT mapping is associating CSF 2.0 outcomes with NIST Special Publication (SP) 800-53 controls that can be implemented to help achieve the outcomes. In this way, CSF 2.0 provides a common language that facilitates access to a large number of other resources.

This publication supersedes SP 800-61r2 (Revision 2), *Computer Security Incident Handling Guide* [SP800-61r2].

1.2. Document Structure

The remainder of this document is organized into the following sections and appendices:

- Section 2 discusses how incident response has evolved to become a critical part of cybersecurity risk management, as well as how the concept of the incident response life cycle has changed to reflect that.
- Section 3 presents incident response recommendations and considerations for an organization's cybersecurity risk management practices. They are organized and documented as a CSF 2.0 Community Profile.
- The References section lists references cited throughout this publication.
- Appendix A and Appendix B provide an acronyms list and a glossary, respectively.
- Appendix C contains a change log of the major changes made since the previous revision.

2. Incident Response as Part of Cybersecurity Risk Management

This section explains the fundamental concepts of incident response as an integral part of cybersecurity risk management. Section 2.1 explores the incident response life cycle and proposes a new life cycle model based on CSF 2.0 Functions. Section 2.2 discusses incident response roles and responsibilities both inside and outside an organization. Finally, Section 2.3 briefly examines incident response policies, processes, and procedures.

2.1. Incident Response Life Cycle Model

Fig. 1 depicts the incident response life cycle model illustrated in the previous version of this publication [SP800-61r2].

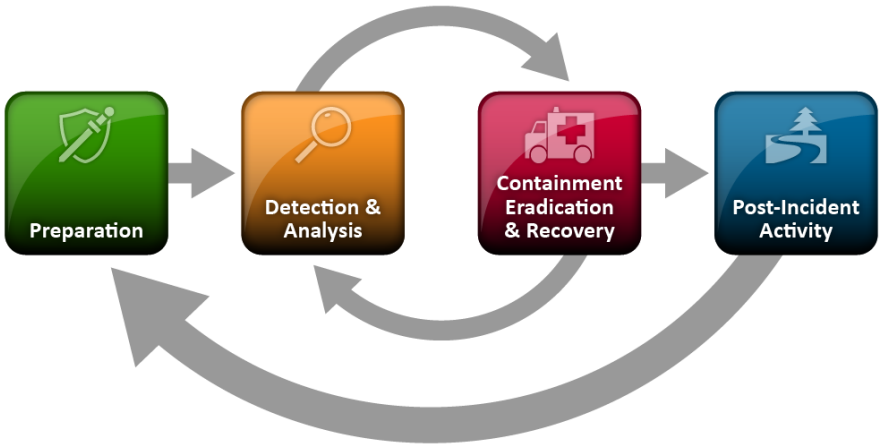


Fig. 1. Previous incident response life cycle model

At that time, incidents were relatively rare, the scope of most incidents was narrow and well-defined, and incident response and recovery was usually completed within a day or two. Under those conditions, it was realistic to treat incident response as a separate set of activities performed by a separate team of personnel and to depict all incident response activities as part of a circular life cycle. Formal post-incident activities would identify needed improvements and feed them into the preparation stage, thus starting the cycle again. Incident response activities were typically intermittent rather than continuous.

However, the current state of incident response has greatly changed since then. Today, incidents occur frequently and cause far more damage. Recovering from them often takes weeks or months due to their breadth, complexity, and dynamic nature. Incident response is now considered a critical part of cybersecurity risk management that should be integrated across organizational operations. The lessons learned during incident response should often be shared as soon as they are identified, not delayed until after recovery concludes. Continuous improvement is increasingly necessary for all facets of cybersecurity risk management in order to keep up with modern threats.